SBMS API ENDPOINT CATALOGUE

Prepared: 2026-11-02 **Revision described:** `fix/sbms-completion-work` @ `d6b5032` **Scope:** every HTTP route the Express application mounts, as read from `backend/src/routes/*.js` and `backend/src/index.js:65-99`, with the guard chain, request contract, success shape, refusal conditions and the test that covers it. **Not in scope:** request or response bodies containing real beneficiary data (none is reproduced here), and any handler that exists in code but is not mounted (see §7.1).

---

1. Method and conventions

Routes were extracted mechanically from the twelve router files and cross-checked against the mount table in `index.js`. Controller contracts were read from the Zod schema in each controller and from the explicit `res.status(...)` calls. Where this catalogue states a refusal condition, that condition exists as an explicit branch in the controller; nothing here is inferred from naming.

Convention	Value
Base URL	`http://localhost:5000/api` in development; `https://<api-host>/api` in deployment
Transport	HTTPS in deployment; JSON request and response bodies
Body limit	100 kB (`index.js:64`); oversize bodies are refused before routing
Authentication	`Authorization: Bearer <JWT>`; token signed HS256, `expiresIn: 8h`
Identity resolution	`decoded.id` or `decoded.sub`; the role is re-read from the `users` row on every request, and an inactive account is refused (`middleware/auth.js:20-24`)
Success envelope	Object or array as documented; list endpoints return a bare array unless stated
Error envelope	`{ message }` or `{ error }` depending on the router family; a 5xx never carries an internal message
Roles	`admin`, `field_officer`; `requireRole` refuses with 403, a missing or expired token with 401

2. Public, unauthenticated endpoints

#	Method and path	Guard	Success	Failure	Controller
1	`GET /api/health`	none	200 liveness object	—	inline, `index.js:69-72`
2	`GET /api/ready`	none	200 `{status: ready}`	503 generic body when a required table or the expected database identity is absent	inline + `services/databaseReadiness.js`
3	`POST /api/verify`	`verificationRateLimit` (10 / IP / 15 min), JSON parser	200 `{found: true or false}` and nothing else	400 for a body that is not exactly `{token}` of 64 lowercase hex; 429 when the budget is exhausted; 503 `{error: temporarily_unavailable}` on lookup failure	`verification.controller.js`
4	`POST /api/certificates/verify`	`certificateRateLimit` (20 / IP / 15 min), JSON parser	200 authenticity facts only: status, certificate reference, award period, issue and approval dates, issuing authority	400 malformed body; 429; 503	`certificates.controller.js:251-290`

Endpoints 3 and 4 are mounted before the shared JSON body parser, so an abusive client is refused before its body is parsed (`index.js:65-67`). Neither returns a student name, school, UPI or national identifier; the certificate endpoint additionally never returns the award amount.

3. Authenticated endpoint catalogue

3.1 Authentication — `/api/auth`

Method and path	Roles	Request	Success	Failure
`POST /api/auth/register`	none (public)	any	—	410 always: the route returns a fixed refusal and the `register` controller beneath it is unreachable (see §7.1)
`POST /api/auth/login/admin`	none; `loginRateLimit` 10 / IP / 15 min	`{email, password}`	200 `{message, token, user}`	400 invalid body; 401 invalid credentials; 403 when the account is a field officer
`POST /api/auth/login/field-officer`	none; same limiter	`{email, password}`	as above	400; 401; 403 when the account is an administrator
`GET /api/auth/me`	any authenticated	—	200 current user row	401 when the account no longer exists or is inactive

The two sign-in routes share one limiter instance, so ten attempts across both endpoints exhaust the budget for that client IP.

3.2 Users — `/api/users` (administrator only, router-level guard)

Method and path	Request	Success	Failure
`GET /api/users`	—	200 array of users	403 for a field officer
`POST /api/users`	`{full_name, email, password (8-72), role}`	201 created user	400 validation; 409 duplicate email
`PATCH /api/users/:id/role`	`{role}`	200 updated user	400 unsupported role; 404 unknown user; 409 self-demotion and last-administrator protection

3.3 Students — `/api/students` (field officer only, router-level guard)

Method and path	Request	Success	Failure
`GET /api/students/schools`	—	200 the five approved school names	403 for an administrator
`GET /api/students`	—	200 array of student records	403
`GET /api/students/:id`	—	200 student record	404 `Student not found`
`POST /api/students`	`full_name`; `date_of_birth` (YYYY-MM-DD); `school_code` (enum of five); `guardian_id`; `upi`; `birth_certificate_number`; `national_id_number`; `primary_phone` (+254[17] plus eight digits)	201 `{message, student, qr_code, duplicate_flags[], duplicate_screening{}}`	400 `Invalid student data` with a Zod `errors` block; 503 when screening is unavailable

The 201 body is the richest contract in the system. It returns the created student, a `data:` URL QR image, every review case created, and a `duplicate_screening` block carrying `model_version`, `review_threshold`, `high_priority_threshold`, `thresholds_validated: false`, `score_is_calibrated_probability: false`, `aggregation_policy`, `candidates_considered`, `candidates_qualifying` and `candidates_suppressed`.

3.4 Duplicate review — `/api/duplicate-flags` (administrator only)

Method and path	Request	Success	Failure
`GET /api/duplicate-flags`	—	200 queue with identifiers masked, `priority` band, model version, cutoff and policy block	403
`GET /api/duplicate-flags/:id/identifiers`	—	200 revealed identifiers; the disclosure is written to the audit log	404 `Duplicate flag not found`
`POST /api/duplicate-flags/evaluate`	`{pairs: [{label, first, second}]}`, 1-30 pairs, `upi` required on each side	200 score and feature vector per labelled pair	400 validation
`POST /api/duplicate-flags/scan`	—	200 rescan of the existing registry	controller-specific 4xx/5xx paths
`PATCH /api/duplicate-flags/:id`	`{decision: confirmed_duplicate | not_duplicate | needs_verification, reason (>=5 chars), notes}`	200 `Review decision recorded` plus a `duplicate_review_events` row	400 `Select a decision and provide a reason of at least 5 characters.`; 404; 409 when the case is already terminal

3.5 Bursary awards and certificates — `/api/awards`

Method and path	Roles	Request	Success	Failure
`GET /api/awards`	admin, field_officer	—	200 `{awards: []}`	403
`POST /api/awards`	field officer	`{student_id (uuid), requested_amount (>0)}`	201 `{message: Award submitted., award}`	400 `Choose a student and enter a positive requested amount.`; 404 `Student not found.`; 409 `Add the student's school before submitting an award.`
`POST /api/awards/:id/verification`	field officer	`{outcome: verified | not_found | needs_investigation, notes (>=5), evidence_ref}`; `evidence_ref` mandatory when `outcome = verified`	201 `Verification recorded.` plus a `bursary_award_verification_events` row	400 `Provide an outcome, notes, and evidence for verified cases.`; 404 `Award not found.`; 409 `Verification is closed after an award decision.`
`PATCH /api/awards/:id/decision`	admin	`{decision: approved | rejected, approved_amount (required when approved), reason (>=5)}`	200 `Award approved.` or `Award rejected.`	400 `Choose approve or reject and provide a reason.`; 404; 409 `This award already has a decision.`, `Verify the beneficiary before approving this award.`, `Resolve duplicate review cases before approving this award.`
`POST /api/awards/:id/certificate`	admin	`{award_period}` optional, `2026` or `2025/2026`	201 `Certificate issued.` with reference, verification URL and QR data URL	400 malformed period; 404 `Award not found.`; 409 not approved, already issued, or student record missing
`GET /api/awards/:id/certificate`	admin, field_officer	—	200 staff view with QR and verification URL	404 `No certificate has been issued for this award.`

Method and path	Roles	Request	Success	Failure
`GET /api/awards/:id/certificate.pdf`	admin, field_officer	—	200 `application/pdf`, A4 landscape, `Content-Disposition: attachment`	404
`POST /api/awards/:id/certificate/revoke`	admin	`{reason (>=5)}`	200 `Certificate revoked.`	400 `Enter a reason of at least 5 characters for revoking the certificate.`; 404; 409 `This certificate has already been revoked.`

3.6 Disbursements — `/api/disbursements`

Method and path	Roles	Request	Success	Failure
`GET /api/disbursements`	authenticated (router-level `authenticateToken` only)	—	200 array with `exception_reasons[]` and `acknowledgement_overdue_days` per row	401
`GET /api/disbursements/exceptions`	admin, field_officer	—	200 `{deadline_days, exceptions[]}`	403
`POST /api/disbursements`	admin, field_officer	`{award_id, amount (>0), payment_method (2-80), payment_reference, disbursement_date}`	201 `Payment recorded as issued; clearance is not confirmed.`	400; 404 `Award not found.`; 409 `Only verified, approved awards can be disbursed.`, `Resolve duplicate review cases before disbursing this award.`, over-amount and duplicate-block refusals
`PATCH /api/disbursements/:id/payment-status`	admin, field_officer	`{payment_status: cleared | failed | cancelled, evidence_ref (required for cleared), notes (>=5 for failed/cancelled)}`	200 `Payment marked <status>.` plus a `disbursement_reconciliation_events` row	400; 404 `Payment not found.`; 409 `This payment status cannot be changed.`, `A payment with a receipt record cannot be failed or cancelled.`
`PATCH /api/disbursements/:id/acknowledgement`	admin, field_officer	`{acknowledged_amount (>=0), evidence_ref (>=1), notes}`	200 recorded receipt, `acknowledged` or `discrepancy` derived by comparing cents	400 `Enter the received amount and evidence reference.`; 404; 409
`PATCH /api/disbursements/:id/award`	admin	`{award_id, reason (>=5)}`	200 legacy payment linked to an approved award	400; 404; 409 when the award does not match the student, is not approved, or is already linked

3.7 Eligibility, reports, settings, dashboard, audit, beneficiaries

Method and path	Roles	Request	Success	Failure
`POST /api/eligibility`	field officer	`{student_id, fee_balance, household_income, vulnerability_status, siblings_in_school, prior_bursary_history}`	200 `{score, category, breakdown{}, reasons[]}` and the result is persisted on the student row	400 `Fee balance, household income, and siblings must be non-negative numbers`, `Invalid vulnerability status`, `Invalid prior bursary history`; 404 `Student not found`

Method and path	Roles	Request	Success	Failure
`GET /api/reports/export`	admin	query `start_date`, `end_date`	200 PDF stream	400 `start_date and end_date are required`, `start_date cannot be after end_date`
`GET /api/settings/threshold`	admin	—	200 the three cut-offs in force	403
`PUT /api/settings/threshold`	admin	`{threshold, reviewThreshold, mlReviewThreshold}` at least one	200 `Duplicate review settings updated successfully`	400 each out-of-range field and `Duplicate threshold must be greater than or equal to the review threshold`
`GET /api/admin/dashboard`	admin	—	200 totals, six-month trend series, recent audit activity	403
`GET /api/audit-logs`	admin	—	200 audit rows	403
`GET /api/beneficiaries`	any authenticated	—	200 legacy beneficiary rows	401
`GET /api/beneficiaries/:id`	any authenticated	—	200 one legacy row	404 `Not found`
`POST /api/beneficiaries`	field officer	legacy beneficiary fields	201 created row	403
`PUT /api/beneficiaries/:id`	field officer	legacy beneficiary fields	200 updated row	404
`DELETE /api/beneficiaries/:id`	field officer	—	204 no content	404

`/api/beneficiaries` is the legacy module retained for compatibility. It is deliberately not aligned with `students`, and its `scholarship_amount` column is **not** mapped to any award or payment amount (see `SBMS_DATABASE_SCHEMA_AND_DATA_DICTIONARY.md` §8).

4. Endpoint counts

Family	Endpoints	Public	Admin only	Officer only	Both roles	Authenticated, any role
health / ready / verify / certificate verify	4	4	—	—	—	—
auth	4	3	—	—	—	1
users	3	—	3	—	—	—
students	4	—	—	4	—	—
duplicate-flags	5	—	5	—	—	—
awards + certificates	8	—	3	1	4	—
disbursements	6	—	1	—	4	1
eligibility	1	—	—	1	—	—
reports / settings / dashboard / audit	5	—	5	—	—	—

Family	Endpoints	Public	Admin only	Officer only	Both roles	Authenticated, any role
beneficiaries (legacy)	5	—	—	3	—	2
Total	**45**	**7**	**17**	**9**	**8**	**4**

The `auth` public count includes the 410 registration stub and the two sign-in routes.

5. Error catalogue

Status	Meaning in SBMS	Typical body	Where produced
400	Request failed field-level or cross-field validation	`{message}` or `{error, errors}`	Zod `safeParse` in every controller
401	Missing, malformed or expired token; account deleted or deactivated	`Authentication token required`, `Invalid or expired token`, `User account no longer exists`	`middleware/auth.js`
403	Authenticated but not permitted, or account presented at the wrong sign-in endpoint	`You do not have permission to access this resource`	`middleware/requireRole.js`; `auth.controller.js:52`
404	Referenced record does not exist, or a terminal case is re-decided	entity-specific message	controllers
409	State transition refused: award not verified, duplicate open, already decided, already issued or revoked, amount exceeded	state-specific message	controllers, backed by database CHECK constraints
410	Public registration disabled	`Public registration is disabled.`	`auth.routes.js:9-11`
429	Rate-limit budget exhausted for this client IP	generic message unique per limiter	`middleware/rateLimitWindow.js:29,38`
503	Screening unavailable, database not ready, or public lookup failed	registration error sentence; `{status: not-ready}`; `{error: temporarily_unavailable}`	`students.controller.js:78`; `index.js:73-87`; `verification.controller.js:22`
500	Unexpected failure; the message is always `Internal server error` and the stack never leaves the process	`Internal server error`	`middleware/errorHandler.js:59-78`

6. Rate limits and budgets

Limiter	Budget	Window	Scope	Endpoints	Limitation
`loginRateLimit`	10 requests	15 min	per client IP, shared by both sign-in routes	`/auth/login/admin`, `/auth/login/field-officer`	Process-local; resets on restart
`verificationRateLimit`	10 requests	15 min	per client IP, own counter map	`/api/verify`	Process-local; not shared across instances
`certificateRateLimit`	20 requests	15 min	per client IP, own counter map	`/api/certificates/verify`	Process-local
JSON body limit	100 kB	—	per request	all parsed routes	—
Tracked-IP ceiling	10 000 IPs per limiter	—	per limiter instance	all three limiters	A new IP is refused with 429 once the map is full (`rateLimitWindow.js:28-30`)

Client IP resolution uses the socket address unless `TRUST_PROXY_HOPS` is set, in which case Express resolves the forwarded client. Forwarded headers are never trusted by default, and a forged `X-Forwarded-For` does not create a fresh budget (asserted by `verification.test.js`).

7. Contract notes and honest limitations

7.1 Handlers that exist but are not reachable

Item	State	Evidence
`auth.controller.register`	Implemented with validation, hash and duplicate-email handling, but the route returns 410 before it is called	`auth.routes.js:9-11` versus `auth.controller.js:14-35`
Public self-registration	Intentionally impossible; accounts are created through `POST /api/users` by an administrator	FR-03

These are reported as dead code, not as features. A reader should not infer from the existence of `registerSchema` that public sign-up works.

7.2 Role asymmetry between the API and one shared screen

`/api/students` is guarded at router level for `field_officer` only, so an administrator calling `GET /api/students` receives 403. The disbursement screen is rendered for both roles and calls `GET /students` to populate the award-application picker (`frontend/src/pages/Disbursements.jsx:54`), which means that picker has no data for an administrator. This was found by reading the guard chain against the page; it has **not** been exercised in a browser for the administrator role, so it is recorded as an inspection finding rather than a reproduced defect.

7.3 What the API deliberately does not expose

- No endpoint returns `students.qr_token`; the value is stripped from every student response and only the QR image and verification URL are returned.
- No endpoint reveals a beneficiary identifier without an administrator request that is written to the audit log.
- No endpoint reports eligibility, award, payment or receipt status to an unauthenticated caller.
- No endpoint deletes a student, a duplicate case, an award, a payment, an audit row or a certificate. Certificate revocation is a status change, not a deletion.

7.4 Coverage of this catalogue by tests

Every route in §3 has at least one assertion in the backend suite **except**: `POST /api/duplicate-flags/scan`, the plain `GET /api/disbursements` list, the success-path arithmetic of `POST /api/eligibility`, the PDF bytes of `GET /api/reports/export`, `GET /api/settings/threshold`, `PATCH /api/beneficiaries/:id`, `DELETE /api/beneficiaries/:id`, and the dashboard counters. Those exclusions match the partial ratings in `SBMS_REQUIREMENTS_AND_SCOPE_CATALOGUE.md` §8 and are re-listed with the test inventory in `SBMS_TEST_EVIDENCE_CATALOGUE.md` §7.

7.5 Revision discipline

The endpoint set was extracted from the working tree at `d6b5032`. Two root-level reports cited elsewhere in this documentation set are untracked at that revision (`SBMS_O10_O11_IMPLEMENTATION_REPORT.md`, `SBMS_PHASE_2_SUPERVISOR_FINDINGS_REVIEW.md`), and `.gitignore` still lists `ml-service/model/*.joblib` although the artefact is tracked. Neither affects the API contracts above, but both affect what a future reader can reproduce from a clean clone; they are carried as G-27 and G-28 in the gap register.